



Leis, Normas e Padrões

Privacidade · Confiabilidade

Portal Interno de Automação · Vivo / Telefônica Brasil

Guilherme Reis
Nicolas Lobo
Vinicius Trevisan





O Projeto — Caso Real

Portal Interno de Automação · Vivo

- Único desenvolvedor responsável dentro da área.
- Processa dados pessoais de dezenas de milhares de clientes
- Robôs RPA automatizam tarefas em sistemas legados da Vivo
- Portal web usado por equipes distribuídas via SSO corporativo

Next.js / React

Portal Web Interno

Python Flask/FastAPI

Backend & APIs REST

Playwright + Python

Robôs RPA

SQL Server / PostgreSQL

Banco de Dados



Riscos de Privacidade

R1

Data minimization ausente

Robôs recuperam conjuntos completos de dados quando poderiam operar apenas com campos necessários, ampliando exposição.

R2

Log de auditoria insuficiente

Não há rastreabilidade granular de quais dados pessoais foram acessados, dificultando resposta a incidentes (LGPD art. 37).

R3

Retenção indefinida em staging

Dados pessoais em tabelas temporárias sem política de expiração. LGPD art. 15 exige descarte após finalidade cumprida.

R4

Credenciais em texto plano

Versões anteriores dos scripts armazenaram credenciais hard-coded, risco de reintrodução sem revisão formal de segurança.

R5

Parceiros sem DPIA verificada

Dados enviados a APIs de parceiros sem verificação de conformidade LGPD, expondo a empresa a responsabilidade solidária.

Riscos de Confiabilidade

R6

Ponto único de falha

Sistema mantido por 1 desenvolvedor, sem documentação suficiente para outro assumir. Risco operacional crítico.

R7

Sem homologação formal

Não existe ambiente espelhando produção. Atualizações vão direto de local para produção, aumentando risco de falhas.

R8

Monitoramento reativo

Falhas detectadas só quando usuário reporta problema. Sem alertas proativos ou dashboard de saúde dos processos.

R9

Dependência de legados sem SLA

Robôs dependem de sistemas legados sem SLA interno. Indisponibilidade causa falha em cascata sem retry/circuit breaker.

R10

Plano de DR não testado

Backup existe via infraestrutura corporativa, mas restauração específica da aplicação nunca foi validada em prática.



Regulamentações Aplicáveis

LGPD

Lei 13.709/2018

Principal norma. Data minimization, logs de tratamento, notificação de incidentes ($\leq 72h$), direitos dos titulares.

MCI

Lei 12.965/2014

Marco Civil da Internet. Guarda de logs de acesso por 6 meses (conexão) a 1 ano (aplicação).

ISO 27001

SGSI — Requisitos

Sistema de Gestão de Segurança da Informação. Controle de acesso, gestão de incidentes, desenvolvimento seguro.

ISO 27002

Controles de Segurança

Criptografia TLS 1.2+, gestão de vulnerabilidades, backup, SSDLC, revisão de código com foco em segurança.

ANATEL 740

Resolução 2020

SGSI obrigatório para telecomunicações. Proteção de infraestrutura crítica, gestão de riscos cibernéticos, notificação à ANATEL.

Controles e Mecanismos Propostos

C1



Data Minimization

LGPD Art. 6º

C2



Log granular de dados pessoais

LGPD Art. 37 · MCI

C3



Política de retenção (TTL 7 dias)

LGPD Art. 15

C4



Cofre de segredos (Key Vault)

ISO 27002 A.9

C5



Documentação técnica completa

ISO 27001 A.7

C6



Homologação com dados anonimizados

ISO 27002 A.12

C7



Monitoramento proativo + alertas

ISO 27002 A.12 · ANATEL

C8



Retry + Circuit Breaker (legados)

ISO 27002 A.17

C9



Teste de DR semestral

ISO 27001 A.17

C10



Plano de resposta a incidentes

LGPD Art. 48 · ANATEL



Benefícios da Conformidade

R\$50M

Multa máxima por infração LGPD (art. 52) — evitada com conformidade

$\leq 72h$

Prazo de notificação de incidentes exigido pela LGPD e ANATEL 740

6–12

Meses de retenção de logs exigidos pelo Marco Civil da Internet

100%

Das penalidades previstas são evitáveis com controles técnicos adequados



Conclusão

1

O Portal de Automação da Vivo processa dados pessoais em escala — LGPD e ANATEL 740 se aplicam integralmente.

2

10 riscos identificados: 5 de privacidade, 5 de confiabilidade — todos mitigáveis com controles técnicos viáveis.

3

Conformidade com LGPD, Marco Civil, ISO 27001/27002 e ANATEL 740 não é opcional — é obrigação legal e vantagem competitiva.

4

Custo de prevenção << custo de remediação pós-incidente (investigação forense + notificações + multas + reputação).

"Better safe than sorry!"